e) Copy the `Accept` header directly to the `Content-Type` header in the response.

2.7 What hasn't been covered

In this chapter you've seen several attacks that can occur through mishandling user input, including devastating database injection and XSS attacks that can completely undermine the security of your API. And that's just from implementing a single operation! The good news is that these basic secure coding practices can be applied to the other operations too, and to all the APIs that you write yourself. Rather than repeating myself, I'll skip over the implementation of the rest of the API. If you are interested, you can check out the full implementation from the GitHub repository accompanying this book: https://github.com/NeilMadden/apisecurityinaction.

Despite the firm foundation you've established in this chapter, the Natter API is still a long way from being secure. All requests and responses are still being sent over plain HTTP, so can be intercepted and altered by anybody on the same network. There is also no access control at all, so anyone can do what they like. That isn't very much now, but as the API grows in functionality, so do the opportunities for malicious users to cause trouble. All these issues and more are addressed in chapter 3.

2.8 Summary